

选择题

资产保护类型:

1. 被动攻击包括**传输报文泄露**和**通信流量分析**。
2. 网络安全信息服务应包括**机密性服务**, **完整性服务**, **可用性服务**, **可审性服务**。
3. 服务器检测到Dos攻击, 若攻击数据包里面源IP和目的IP相同, 则该Dos攻击可能为Land攻击; 若服务器接收到大量的CMP-Echo-Reply响应包, 则该Dos攻击可能为Smurf攻击; 若服务器上面出现大量的TCP半连接, 则该Dos攻击可能为SYN Flood_攻击。
4. 因特网的域名系统被设计成一个**联机分布式数据库系统**, 并且采用**分层树状结构**的命名方法。
5. DNS查询方式分为**递归查询**和**迭代查询**, 客户端与服务器之间通常采用**递归查询**, 服务器之间通常采用**迭代查询**。
6. 端口扫描某服务器, 若发现**53**号端口开放, 则该服务器可能开放的服务是**DNS**; 若发现**23**号端口开放, 则该服务器可能开放的服务是**Telnet**; 若发现**21**号端口开放, 则该服务器可能开放的服务是**FTP**。
7. 秘密扫描技术是一种**不被审计工具所检测**的端口扫描技术, 现有的秘密扫描技术有TCP FIN, TCP ACK, TCP NULL, TCP XMAS, TCP分段扫描。其中TCP ACK_扫描无法获得目标主机端口开放情况。
8. 安全策略的实施原则有**最小特权原则**, **最小泄露原则**, **多级安全策略**。
9. 强制访问控制模型中, 考虑到偏序关系, 主体对客体的访问方式主要有**向下读**, **向下写**, **向上读**, **向上写**。
10. MAC模型中的几种主要模型有**Lattice模型**, **BLP模型**, **Biba模型**。其中Lattice模型适合需要对信息资源进行明显分类的系统; 其中强调信息的机密性而忽略了信息完整性的模型是**BLP模型**。
11. 防火墙是**位于2个或多个网络间实施网间访问控制的一组组件集合**。
12. 防火墙访问控制方法有**服务控制**, **行为控制**, **用户控制**, **方向控制**。
13. **状态检测防火墙**是在动态包过滤防火墙基础上加上**状态检测**机制形成的。
14. 防火墙体系架构中**屏蔽子网**体系架构相对来说是入侵者最难攻破的。该体系架构中的主要组成部分有**外部路由器**, **堡垒主机**, **内部路由器**。其中**堡垒主机**是整个架构的核心。
15. CIDF的主要组成部件包括**事件产生器**, **事件分析器**, **响应单元**, **事件数据库**。
16. 常见的通用入侵检测模型有**denning模型**。
17. 基于异常的入侵检测的检测原理是1) **正常行为的特征轮廓**2) **检测系统运行情况**3) **是否偏离预设门限**; 其常用检测算法是**统计分析**, 该检测算法的一个最大缺点是**利用统计轮廓的动态自适应性**, 这常常会导致系统将入侵行为判为正常行为。
18. 基于误用入侵检测的原理是**根据已知系统或软件的漏洞来检测入侵行为**; 常用的检测算法有**专家系统**, **模型推理**, **状态转换分析**, **完整性分析**。
19. VPN的定义是**依靠IP或其它NSP在公用网络基础设施之上构建的专用的数据通信网络**。其特点是**封闭的用户群**, **安全性高**, **服务质量有保证**。其功能有**数据源身份验证**, **数据机密性保护**, **数据完整性保护**, **重放攻击保护**。
20. 隧道技术实际是一种**数据封装**, 将一种协议X封装在另外一种协议Y中, 从而实现协议X对公用传输网络(采用协议Y)的透明性。
21. 隧道协议包含**乘客协议**, **封装协议**, **运载协议**三种协议。
22. 根据网络类型的差异, 可以将VPN分为**Client-LAN**和**LAN-LAN**这2种类型。
23. **PPTP**和**L2TP**协议都是链路层安全协议, 其中**PPTP**协议要求互联网必须为IP网络。L2TP协议体系主要由**LAC**和**LNS**构成。
24. IPSec体系包含**AH**和**ESP**协议, 其中**AH**协议只有认证功能; **ESP**协议有认证和加密功能。
25. 在IPSec协议体系中, **IKE**协议的作用是在**通信双方之间通过协商建立SA**。
26. **IKE**密钥交换第一阶段的目的是在**通信双方之间建立一对ISAKMP SA**, 进而建立一条安全的通信信道。第二阶段的目的是在**通信双方之间建立IPSec SA**。
27. **IKE**密钥交换第一阶段主模式分3个步骤, 这3个步骤分别是**策略协商交换**, **DH公开值及nonce交换**, **身份验证交换**。
28. **SSL**协议分2层, 低层是**SSL记录协议**, 高层是**SSL握手协议**, **SSL密码变化协议**和**SSL警告协议**。

- 29. 邮件数据处理顺序是签名-->压缩-->加密，压缩在签名之后的目的是便于使用多种压缩算法；加密在压缩之后的目的是减少消息的冗余量，使得加密强度更大，密码分析难度变大。
- 30. PGP功能有数字签名，消息加密，压缩，邮件兼容，数据分段。
- 31. vpn的功能**数据机密性保护、数据完整性保护、数据源身份认证、重放攻击保护**
- 32. 端口扫描技术**全连接扫描、半连接扫描、秘密扫描**
- 33. 访问控制3要素**主体S、客体O、控制策略A**
- 34. nat三种类型**静态NAT、NAT池、端口NAT**
- 35. 入侵检测按照体系结构分类**集中式、等级式、协作式**

简答题

概率大

Teardrop是什么类型的攻击，详细描述攻击的原理（TCP）

MTU是最大的传输单元，大的数据包再传输时需要分段，teardrop就是根据分割重组之间的漏洞向目标机器发送损坏的IP包，(如重叠的包或者过大的载荷包)，使得接收方重组时数据包长度过大甚至为负数，造成溢出。

ping of Death(ICMP)

早期的操作系统在处理ICMP数据包时只分配了64kb的缓冲区来存放收到的数据包，攻击者可以在icmp数据包之后附加非常多的冗余信息，使得数据包大小超过65535字节，这样接收方获取数据包时会发生栈溢出，导致系统崩溃。

Land

攻击者发送一个构造好的SYN数据包，该包的起始地址和接收地址都是目标机器的ip地址，这样目标机器接收到该数据包，会向自身发送一个SYN ACK 数据包，接着再向自身发送ACK数据包并创建一个空连接，目标主机每收到这样一个SYN数据包都会创建这样一个空连接，且保留，直到超时。

SYN Flood

每个机器都需要为半连接分配一定的资源

这种半连接的数量是有限制的

攻击者利用tcp协议的三次握手过程，打开大量的半连接。（不可达）

接收方产生大量的半连接，不能再接受新的tcp连接（速度差）（目标多支持tcp即可）（难以跟踪）

Smurf

攻击者向广播地址发送ICMP Echo请求，并且将请求源地址设为目标主机的地址

广播地址所在网络的所有主机会相应ICMP请求，向目标主机发送ICMP Echo-Reoly应答

目标主机被这些应答淹没。

Http洪水

用HTTP GET FLOOD反复请求服务器上的资源文件，大量消耗服务器上的资源，导致服务器崩溃

DNS欺骗的原理，DNS欺骗的各个步骤。（下毒针对服务器）

DNS应答包被客户端接受需要满足以下五个条件

- 1、应答包question域和请求包question域的域名信息一致。
- 2、应答包的Transaction ID和请求包中的Transaction ID一致。
- 3、应答包的源IP地址与请求包的目的IP地址一致。
- 4、应答包的源IP地址和端口与请求包的源IP地址和端口一致。
- 5、第一个到达的符合以上四个条件的应答包。

从以上五个条件可以看出，最初设计DNS时没有考虑它的安全问题，这导致DNS协议存在很多漏洞，这使得DNS很容易受到攻击。

DNS (Domain Name System) 域名解析协议，用于将域名解析成IP地址

原理：（1）DNS只使用序列号来进行有效性鉴别，有序列号攻击的风险。

（2）DNS从协议上看，响应消息可以随意的附加信息，攻击者可以附加任何无关的信息，对信息的完整性造成威胁。

（3）DNS有缓存机制，当客户端或者服务端收到某个域名和IP地址的对应信息是，会放入缓存中，下次直接使用，也有攻击的风险。

步骤：

- （1）攻击者监听客户端和服务端之间的通信
- （2）客户端向服务端请求某个域名的ip地址
- （3）攻击者早于服务端回应一个假的应答包
- （4）服务端回应比较晚，被丢弃
- （5）完成DNS欺骗

ARP欺骗的原理，ARP欺骗的每个步骤。

ARP(Address Resolution Protocol)地址解析协议，用于将ip地址解析成mac地址

ARP欺骗是利用修改主机上的ARP缓存表以达到嗅探的目的，是一种中间人攻击。主机C要对主机A和主机B进行ARP欺骗，要向主机A和主机B分别发送ARP响应包，告诉它们IP地址为IPA的主机的MAC地址为MACC，ip地址为IPB的主机的MAC地址为MACC，这样主机A和主机B的ARP缓存表上就会有IPA-MACC和IPB-MACC的记录，它们之间发送的消息都会发送给主机C。不过ARP缓存表会动态更新，主机C在监听过程中需要不断发送ARP响应包

屏蔽子网体系结构防火墙有几个部分组成，详细描述各个部分的功能

由外部路由器、周边网络、堡垒主机、内部路由器、内部网络组成

外部路由器：保护周边网络和内部网络不受外部网络的侵犯

周边网络：作为一个防护层、可以运行一些信息系统，在受到侵犯时仍能消除对内部网络的监听

堡垒主机：是整个防御体系的核心，可以运行各种代理服务程序

内部路由器：保护内部网络不受周边网络和外部网络的侵犯，执行大部分的过滤工作

内部网络：重要的数据所在，存放机密数据。

优点：

- (1) 需要攻破3个不同的设备才能进入内部网络
- (2) 只对外通告非军事区，保证内部网络不可见
- (3) 内部网络用户通过堡垒主机或代理服务器访问外部网络

snort使用哪种检测技术？检测技术的原理是什么？什么优缺点？

误用检测技术

原理：首先要对入侵行为的特征、环境、次序、完成事件的关系进行描述，通过某种方式预先定义入侵行为，然后监视系统，符合预先定义的入侵行为则认为是入侵

优点：

- (1) 算法简单 (2) 效率高 (3) 消耗系统资源少 (4) 准确率高

缺点：

- (1) 只能检测出预先定义的行为，无法检测出新类型的攻击方式的威胁
- (2) 建立模式库困难：模式库需要更新，依赖于硬件平台，操作系统和系统中运行的应用软件。

专家系统（if-then）、模型推理（结合攻击脚本）、完整性分析

基于异常的IDS的定义？检测原理？优缺点？

定义：任何正常用户的行为都有一定的规律，而入侵会导致用户或者系统行为的异常。首先要总结出正常的用户行为轮廓，当用户行为严重偏离正常行为时则认为是入侵

原理：

- (1) 首先总结正常行为的轮廓
- (2) 检测系统目前的行为
- (3) 查看是否超出预先定义的门限

优点：

- (1) 能检测出未知的行为
- (2) 能检测出冒用账号的行为
- (3) 具有自适应和自学习的能力
- (4) 不需要系统先验知识

缺点：

- (1) 漏报率低，误报率相对较高
- (2) 计算量大，耗用系统资源
- (3) 统计点的选取和参考库的建立比较难

IPSec VPN中AH协议的功能，AH协议有哪两种模式？分析这两种模式的差异

功能：

- (1) 身份认证
- (2) 数据完整性校验
- (3) 重放攻击保护

模式 (1) 传输模式 (2) 隧道模式

差异：

传输模式：在原来的ip头和载荷之间加入AH头

隧道模式：在原ip和载荷之前加入AH头，再在AH头之前加一个新ip头

IPSec VPN中ESP协议的功能，AH协议有哪两种模式？分析这两种模式的差异

ESP功能：

- (1) 身份认证
- (2) 加密数据
- (3) 数据完整性校验
- (4) 重放攻击保护

模式： (1) 传输模式 (2) 隧道模式

差异：

传输模式：在载荷和IP头之间加入esp头，载荷之后加入esp尾，在esp尾加入esp认证

隧道模式：在ip头之前加入esp头，载荷之后加入esp尾，在esp尾之后加入esp认证，在最前面加入新ip头

SSL有哪些主要协议？详细描述SSL数据封装的过程

下层：SSL记录协议

高层：SSL握手协议、SSL密码变化协议、SSL警告协议

数据封装：

分片：把数据进行分片，一般214字节，也可以更小

压缩：无损压缩

计算MAC:计算消息鉴别码

加密：采用CBC加密

SSL全称及其功能？

SSL(Secure Socket Layer)安全套接字层

功能：为TCP协议提出一个可靠的端到端服务

为两个通讯个体之间提供保密性和完整性（身份认证）

SSL连接与会话？

一个连接是一个提供一种合适类型服务的传输

SSL连接是点对点的关系

连接是暂时的，每一个连接于一个会话对应

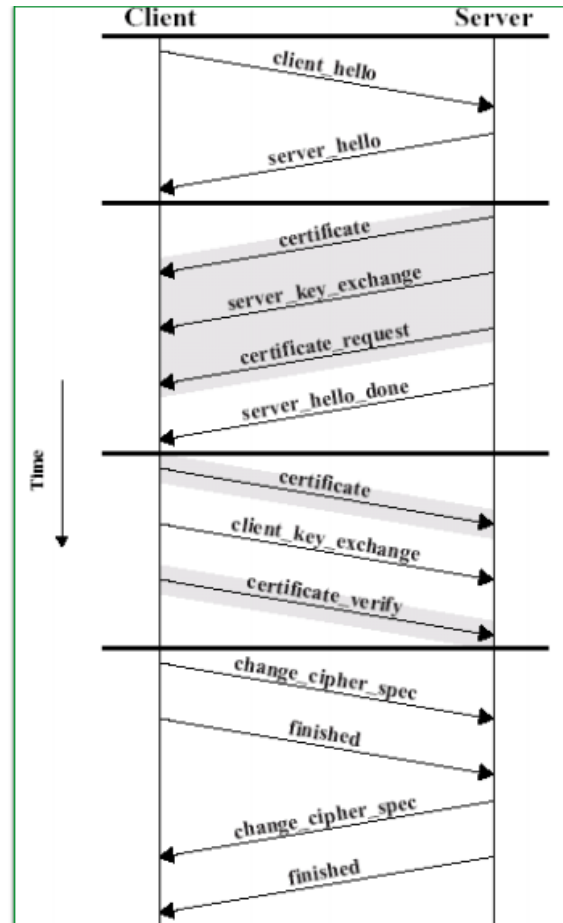
会话是客户和服务端之间的一个关联，定义了一组可供多个连接共享的加密安全参数

用以避免为每一个连接提供新的安全参数所需昂贵的谈判代价

SSL密钥交换整体流程？

整体流程

- (1)、交换Hello消息，对于算法、交换随机值等协商一致
- (2)、交换必要的密码参数，以便双方得到统一的premaster secret
- (3)、交换证书和相应的密码信息，以便进行身份认证
- (4)、产生master secret
- (5)、把安全参数提供给TLS记录层
- (6)、检验双方是否已经获得同样的安全参数



PGP邮件加密的处理过程，简单描述处理顺序及原因

- (1) 发送方生成消息M对消息进行压缩并生成会话密钥
- (2) 用会话密钥对压缩后的消息进行加密
- (3) 用接受方的公钥加密会话密钥
- (4) 将加密后的会话密钥和消息一起传给接收方

接收方

- (1) 收到消息用私钥恢复会话密钥
- (2) 用会话密钥恢复压缩后的消息
- (3) 对消息解压缩得到消息

邮件加密需要先压缩后加密：

原因：

- (1) 先压缩后加密可以减少消息的冗余，增加密码分析的难度

(2) 若先加密，则压缩难以见效

PGP签名加压缩过程？为什么先签名后压缩？

- (1) 发送方生成消息M
- (2) 发送方用SHA-1对消息M，生成一个160位的散列码H
- (3) 用发送者的私钥对H进行加密，并与M连接
- (4) 将消息压缩后传输

接收方

- (1) 收到消息，先解压缩
- (2) 用发送方公钥恢复散列码H
- (3) 用SHA-1同样对消息M生成一个散列码，与H对比，成功则验证

原因：

不需要为了检验签名而保留压缩版本的信息

为了检验而做压缩不能保证信息的一致性，压缩版本不同可能产生不同的结果。

概率小

利用CreateRemoteThread()函数注入过程

利用CreateRemoteThread()函数注入

- 远线程注入DLL的流程：
 - 提升自身进程的权限为SeDebugPrivilege，（如果不注入系统进程，此步骤可省略）。
 - OpenProcess()获取目标进程的句柄。
 - VirtualAllocEx()在目标进程中分配一块内存。
 - WriteProcessMemory()将要注入的DLL路径写入步骤3分配的内存。
 - GetProcAddress()获得LoadLibraryA ()函数的地址。
 - CreateRemoteThread()创建远程线程，线程起始地址设为LoadLibraryA ()函数的地址，线程的参数为步骤4中DLL路径在目标进程中的地址。
 - 等待远程线程结束后退出。

端口扫描技术的原理，tcp connect()扫描优缺点

发送数据包，记录响应，分析响应，得到服务。

利用操作系统的connect () 系统调用，与目标主机端口进行连接，若端口处于侦听状态，则connect () 成功，否则，端口要么不能用，要么没有提供服务。

●优点

- 扫描迅速
- 准确而且不需要任何权限，系统中的任何用户可以使用这个调用
- 可以同时打开多个套接字，加速扫描，使用非阻塞I/O还允许设置一个低的时间用尽周期，同时观察多个套接字

●缺点

- 扫描方式不隐蔽，服务器日志会记录下大量密集的连接和错误记录
- 易被目标主机防火墙发觉而被过滤掉

TCP SYN () 扫描优缺点

→ TCP SYN扫描

向目标特定端口发送一个SYN报文，根据目标主机返回的数据包，只要辨别报文中是含有SYN+ACK标志还是RST标志，就能够知道目标的相应端口是处于监听还是关闭状态。

●优点

- 扫描迅速快，效率高
- 一般不会对目标计算机上留下记录，比较隐蔽

●缺点

- 在大部分操作系统下，扫描主机需要构造适合于这种扫描的包，而通常情况下，必须要有root权限才能建立自己的SYN数据包

防火墙的定义和满足的条件

防火墙是位于两个(或多个)网络间实施网间访问控制的一组组件的集合。

它满足以下条件

- 所有进出被保护网络的通信必须通过防火墙
- 所有通过防火墙的通信必须经过安全策略的过滤或者防火墙的授权
- 防火墙自身应对渗透(peneration)免疫

基于主机系统结构？优缺点？

是根据主机的审计数据和系统的日志发现可疑事件，检测系统可以运行在被检测的主机或单独的主机上

- HIDS优点
 - 性能价格比高
 - 细腻性，审计内容全面
 - 视野集中
 - 适用于加密及交换环境
- HIDS缺点
 - IDS的运行影响服务器的性能
 - HIDS依赖性强，依赖于审计数据或系统日志准确性和完整性，以及安全事件的定义。
 - 如果主机数目多，代价过大
 - 不能监控网络上的情况

基于网络系统结构？优缺点？

根据网络流量、协议分析、单台或多台主机的审计数据检测入侵

- NIDS优点：
 - 服务器平台独立性：监视通信流量而不影响服务器的平台的变化和更新；
 - 配置简单：只需要一个普通的网络访问接口即可；
 - 众多的攻击标识：探测器可以监视多种多样的攻击包括协议攻击和特定环境的攻击。
- NIDS缺点
 - 不能检测不同网段的网络包
 - 很难检测复杂的需要大量计算的攻击
 - 协同工作能力弱
 - 难以处理加密的会话

包过滤防火墙、应用网关防火墙、状态检测防火墙

双重宿主主机体系结构

屏蔽主机体系结构

包过滤防火墙+堡垒主机

pptp l2tp

设计题

电信诈骗

移动互联网

snort

安全问题:

隐私泄露、钓鱼网站、骚扰电话短信、病毒、诈骗

物联网

安全问题:

物理设备安全、数据安全、隐私安全、通信安全、病毒

移动互联网

答:

1、当前移动互联网存在的主要安全问题:

(1) 个人隐私泄露; (2) 钓鱼网站; (3) 骚扰电话、短信、垃圾邮件; (4) 互联网病毒的传播; (5) 集成度高的移动智能终端设备受攻击后难以恢复等等。

2、移动互联网的安全措施和技术:

(1) 国家实施网络安全法, 普及网络安全知识, 净化网络环境;

(2) 杀毒软件对恶意软件的检测、垃圾邮件过滤功能、骚扰电话短信过滤功能;

(3) 移动互联网文件访问控制, 应用隐私权限白名单;

(4) 移动签名服务、移动身份认证技术等等;

3、针对当前移动互联网的问题的一些看法及解决方案:

(1) 首先从大的方面讲, 国家和相关网络公司要投资建立专业的、系统的、相对安全的移动互联网体系, 净化网络环境, 提高网民的安全度;

(2) 落实到个人, 目前大多数的病毒传播以及网络攻击是由于个人网络安全意识匮乏, 所以鼓励网民了解网络诈骗攻击的手段、提高网络保护意识、做好个人安全防护, 可以很大程度解决当前移动互联网的安全问题;

(3) 对于移动互联网, 主要要解决移动设备的安全, 比如设置好移动设备密码、传输加密、敏感操作进行身份认证、软件系统及时更新、启用白名单、支持远程禁用设备等等。

云的发展

人工智能